

Why network segmentation matters — executive brief

For: Managing Director, department heads · **From:** IT (Muhammad Ibrahim Akmal) **Date:** 2026-10-02 · **Length:** 1 page · **Related:** p06-network-access-policy.md , p06-change-record.md

The situation in one sentence

Today every device at Halden — servers, staff laptops, the CCTV recorder, the printers, and a visitor's phone on the guest Wi-Fi — sits on one network, so anything that gets onto it can reach everything on it.

Why that is a business risk, not an IT preference

What happens today	What it means for Halden
A staff laptop is infected by ransomware	The infection can reach the file server, the domain controllers and the backup server without meeting a single barrier. Ransomware appears in 88% of breaches at small and mid-sized businesses (Verizon DBIR 2025)
A visitor joins the guest Wi-Fi	Their device is on the same network as the finance file share
A delivery driver's phone is lost or compromised	Same problem: one network, no separation
The CCTV recorder or a printer is unpatched	Vendor devices are rarely patched; every one of them is a potential way in
The office Wi-Fi password is written on the break-room wall	It has been the same for three years, and everyone who has ever visited still knows it
Remote staff use a port-forwarded remote desktop to the file server	Exposed remote desktop is one of the most common ways ransomware gets in. Exploitation of edge devices and VPNs grew sharply in 2025 (Verizon DBIR 2025)

What changes

Six zones replace the single flat network. Between them the rule is **deny by default**: traffic is blocked unless there is a written, owned reason for it to be allowed.

Zone	What is in it	What it can reach
Servers	Domain controllers, file server, applications	Only what each service needs
Staff	Workstations and laptops	The file server, sign-in, the service desk, the web
Warehouse	Site 2 devices, across an encrypted tunnel	Sign-in and files, as if on site
Management	IT's admin workstation and infrastructure	Itself only — nothing else reaches it

Zone	What is in it	What it can reach
Guest	Visitor devices	The internet, nothing else
Devices (IoT)	Printers, CCTV, scanners	One shared folder for scanning, nothing else
Remote staff	Staff working from home	The same as being in the office, except management systems

Alongside the zones:

- **The exposed remote desktop is removed.** Remote access becomes a VPN with a signed-in second factor (an approval on the user's phone), granted by name to a role, not by a shared password.
- **Corporate Wi-Fi moves from a shared password to certificates.** A device either has a certificate that our own certificate authority issued to it, or it cannot connect.
- **Guest Wi-Fi stays, and is properly separated,** with a voucher issued at reception and a short acceptable-use notice.
- **Company devices resolve names only through our own servers,** so filtering and logging actually apply, and outbound file-sharing and remote-desktop traffic to the internet is blocked.

What it costs, and what it does not fix

- **Cost:** no licence spend. The work is configuration plus two small virtual machines. The main cost is a maintenance window and a short period of user disruption.
- **It does not replace patching, backups, or endpoint protection.** It limits how far a single failure spreads. It is one control among several, not a substitute for them.
- **It will need exceptions.** Departments will sometimes need a system to reach another system. Each exception will be written down with an owner and a review date, so the network does not slowly go back to being open.

What I am asking for

1. **Approval of the network access policy** (`p06-network-access-policy.md`) — who may reach what.
2. **A maintenance window** (outside working hours) for the migration, one zone at a time.
3. **A named approver per department** for access exceptions, so requests are decided by the business that needs them, not by IT on its own.

The outcome we are buying

If one laptop is compromised on a Tuesday afternoon, the incident is one laptop. It does not become the file server, the backups and the payroll data. That is the whole of the argument.

Status of the approvals above: this brief is prepared for approval. Signature blocks stay unsigned until the review actually happens. The lab behind it is an isolated home lab for a fictional company; the technical content and the measurements are real.

Halden Distribution Ltd. — home-lab portfolio artifact (fictional company, real configurations). Generated from p06-exec-brief.md on 2026-10-02.